BeeWise | Lab 3

Postmerge corrective report - DRAFT

PARTIALLY COMPLETE. Security corrections and local emulator/unit verification are complete. Android runtime, live cloud integrations, trusted backend and external review evidence remain open.

This report replaces stale premerge machine claims. Committed Firebase configuration is not evidence that cloud services are enabled, deployed or working.

Audit date: 2026-10-30. Base/main is PR #1 merge dd8b0e1. Corrective source and command evidence are recorded in docs/lab3-report.md and evidence/corrective/.

No runtime screenshots, performance measurements, Firebase Console receipts, external approvals or successful payments are invented. No production or billing change occurred.

Product and 12-screen traceability

Lab 2 behavior and Vietnamese copy retained

01 Home; 02 AI Matching; 03 Search; 04 Tutor Profile; 05 Login; 06 Register. Guests browse active catalog data, evaluate tutor details and preserve tutor context through authentication.

07 Connection Request; 08 Group Chat; 09 Trial Proposal; 10 Class Revision; 11 Payment; 12 Official Schedule. Only a trusted backend may issue invoices, verify payment and publish official schedules.

Additional account/Firebase tools and tutor application screens remain in source. Tutor applicants submit private pending records and do not become public tutors or parents through self-approval.

Figma-derived colors, Nunito/Be Vietnam Pro fonts and the handoff remain authoritative. Design PNGs are references. Device checks at 360dp/412dp, text scaling, keyboard and TalkBack remain NOT RUN.

References: PRODUCT.md, handoff/flutter-handoff.md, docs/design-traceability.md and ux/.

Implementation architecture

Flutter, Riverpod and Firebase boundaries

Flutter screens consume Riverpod providers/controllers. Service adapters isolate Firebase Auth, Firestore, AI Logic, Storage/PDF, FCM, Analytics, Crashlytics, Remote Config and App Check. GoRouter maps product routes; theme tokens stay centralized.

Catalog queries expose active tutors only. AI recommendations are validated against active catalog IDs. Network/configuration failures remain visible instead of fabricating tutors or recommendations.

Parent registration now reauthenticates matching credentials before retrying a missing profile. Existing parent/applicant profiles are not overwritten, and no existing identity is deleted.

Notification history uses per-UID v2 keys and requires matching data.recipientUid. Guests and unknown recipients receive no private inbox. Legacy global history is ignored; async preferences avoid stale isolate caches.

Known limits: 100-tutor search cap, undefined guest quota persistence, server chat-activity projection and nontransactional bounded local notification history.

Firebase security verification

26 real Firestore and Storage emulator tests pass

Tests run only against demo-beewise on local emulators. They cover private tutor applications, no self-approval/public tutor writes, parent profile/devices, active catalog, atomic connection/chat getAfter consistency, messages and responses.

Rules also cover invoices, payment-verification requests, verified schedule reads and Storage PDF reports. Positive and negative cases test owner/cross-user access, forbidden writes, malformed fields, expiry, stale proposal IDs and immutable trusted state.

A simultaneous parent+applicant batch is denied using post-write role checks. Applicants may detach their own stale device registration without gaining parent read/create rights.

Storage checks owner UID, .pdf extension, application/pdf metadata and size strictly below 10 MiB. Metadata validation is not proof that bytes form a genuine PDF. Production deployment and real bucket upload/download recovery remain unverified.

Firebase client config targets beewise-lab-3. Auth provider status, OAuth, App Check, FCM, AI terms, Analytics, Crashlytics, Remote Config and billing were not inspected or changed remotely.

Trusted backend contract

Parent responses cannot create business outcomes

A trusted consultant proposal must exist in the same chat, with the correct kind/role, payload.status pending and a future payload.expiresAt Timestamp. The chat must reference its currentProposalId/currentRevisionId and eligible onboardingStatus.

Parent writes exactly one immutable responses/{proposalId}. Alternate time and adjustment reason must be nonempty and bounded. Client transactions give recovery errors; rules enforce the same boundary against malicious clients.

A trusted idempotent consumer must revalidate ownership, current proposal, expiry and state before processing. Admin SDK bypasses rules, so server-side tests and access control remain required.

Class confirmation may trigger server invoice issuance. A verification request is only pending intent. Real provider receipt, amount/currency and replay checks must precede verified payment and official schedule creation.

No staging endpoint, consultant service or payment backend exists in this repository. New required fields need staging fixture migration. See docs/backend-contract.md.

Automated checks and Android

Static/unit/rules evidence is separate from runtime

PASS: Flutter 3.47.8 pub get; clean dart format; flutter analyze with no issues; 8 Flutter regression tests; 26 Firebase emulator tests; npm audit with zero vulnerabilities.

PASS: pinned ARTEMIS Python SDK imports and collects 26 scenarios. Offline harness checks syntax, unique case IDs and evidence-state guards. Collection does not execute any Android case.

The original Flutter 3.47.3/Dart 3.13.3 fails this project's SDK constraint, and default Java is 8. Portable Flutter/Dart and Temurin 21, dependency caches and build output now use drive D. System PATH/registry were not changed.

Gradle 9.3.1 establishes a real loopback daemon connection under JDK 21; both Firebase emulators run. The historical JDK17 loopback root cause is not reproduced. The quiet build was traced to the required NDK download.

PASS: CI built the debug APK at source 114d682; all three CI jobs passed. APK SHA256 and download provenance are in evidence/corrective/apk-ci.json. No online device or configured AVD was observed; install, launch, crash/logcat and 360dp/412dp captures remain NOT RUN.

ARTEMIS and evidence provenance

26 cases collected; mobile execution blocked

25 Flash regressions plus one 20-minute Pro exploration are authored. Run 21 automatic Flash cases three times, then TC-10/14/15 with fresh operator-sent UID-targeted pushes and TC-26 with operator-entered disposable credentials, each three times.

Runner writes BLOCKED for missing prerequisites, preserves pytest exits, SHA/UTC timestamps and log hashes, rejects reused evidence directories, and marks zero-exit observations PENDING_VERIFICATION.

Require a running host with locally supplied model key, installed APK, online device, authorized Firebase test project/accounts, safe tutor data and fresh trusted backend fixtures. None of those live prerequisites was supplied for this execution.

Export original host traces/replays, check JUnit against observable state and record reviewer/provenance before any PASS claim. AI JSON alone is insufficient evidence. Do not put passwords in model goals or committed traces.

All TC-01 through TC-26 device results remain BLOCKED/NOT RUN. Per-case reasons and resume commands are in docs/test-plan.md and the evidence manifest.

AI use and corrective audit

Internal Codex review; external review unavailable

PR #1 GitHub reviews/comments APIs returned empty arrays. EXTERNAL_REVIEW_NOT_AVAILABLE. No raw hosted AI review transcript or approval exists. Codex static/security review is disclosed as internal self-review.

P1 notification isolation: da73da3, notification_service.dart/app_providers.dart, regression tests for switching/sign-out/recipient/guest/duplicate behavior.

P2 registration recovery: 1bc63f6, auth_service.dart, tests for interrupted-write recovery, existing role preservation and incorrect password denial.

P1 security invariants/P2 workflow: b8f97c4, workflow_service.dart/firestore.rules, same-chat/current/expiry/immutable responses, atomic role/link checks and real emulator regressions.

CI and E2E evidence handling: 114d682. Finding-to-commit-to-test traceability and remaining risks are in docs/code-review.md. No real Firebase account was created and no production data was uploaded.

Release gates and demo

DRAFT remains until independent runtime evidence exists

Release verdict: NOT READY. Supply authorized Android device/AVD, install the CI-built APK and verify primary flows, text scaling, keyboard insets, logcat and authentic 360dp/412dp screenshots with source/APK hashes.

Owner must supply dedicated Firebase test resources and permitted provider setup. Do not change billing, enable paid services, accept AI terms or publish unverified rules automatically.

Implement trusted consultant/invoice/payment/schedule processing and installation ownership checks. Android can show notification payloads before app UID validation; use non-sensitive OS-visible content and verify shade behavior separately.

Run and independently review ARTEMIS traces, Firebase integrations and real staging receipts. Obtain external/human review if required. Complete demo recording using docs/demo-script.md without inventing unavailable service outcomes.

Reproduce: scripts/verify-lab3.ps1 -Flutter <Flutter 3.47.8 path> -Rules -Android; npm --prefix firebase test; python scripts/check_e2e_harness.py. Detailed commands, logs and final CI SHA are in the execution report.